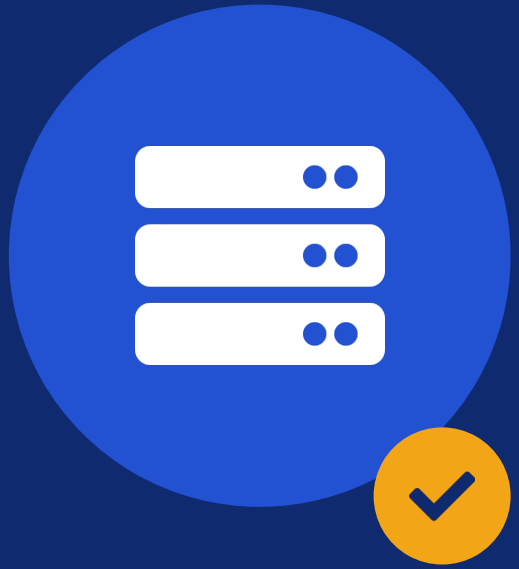
Technology & Security

How Ji-Hajoor is built and protected



Updated 30 October 2026 · Tech stack, security review and reviews engine

At a glance

An event-driven marketplace on Railway, ready for AWS

3
apps: web, Android, iOS

20
services in 5 deployables

14
event types, via Kafka

10
CI workflows



Live on Railway

Every app and service deploys from one repository on each merge.



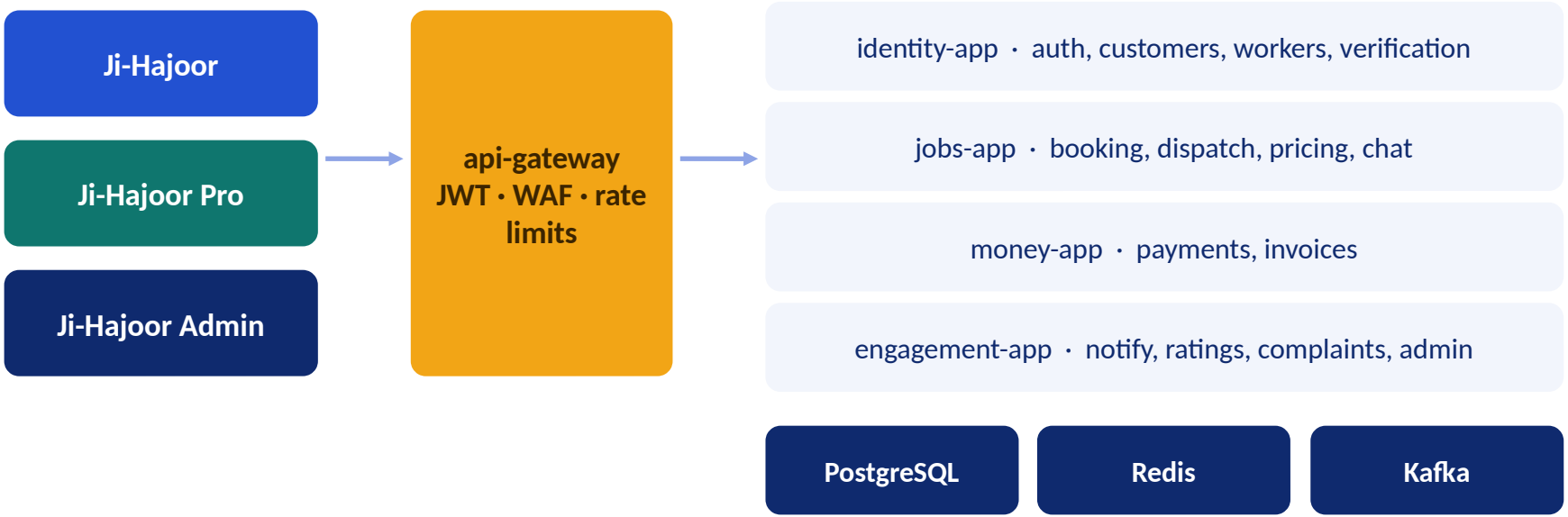
Ready for AWS

EKS, RDS and MSK prepared in Terraform and Helm.

Every change runs unit tests, lint, security scans and a full booking-to-review test before production.

One gateway in, four deployables behind it

Apps → nginx → api-gateway → services → data



Partners: Razorpay · MSG91 SMS · Google and Apple sign-in · Email (SES) · S3

Tech stack

Mainstream, well-supported choices at every layer

Layer	Choice
Apps	React 19, TypeScript, MUI, Vite; Capacitor for Android and iOS
Backend	Java 25, Spring Boot 4.1, Spring Cloud Gateway
Data	PostgreSQL (a schema per service, Flyway), Redis
Events	Kafka with a transactional outbox
Hosting	Railway (Docker) today; AWS EKS, RDS, MSK ready in Terraform and Helm
CI/CD	GitHub Actions; gitleaks, Trivy and npm audit on every change
Partners	Razorpay, MSG91, Google and Apple sign-in, SES email, S3

SECURITY REVIEW · 30 OCTOBER 2026

Secure by design, checked on every change

Defence in depth from the browser to the database. No system can promise it cannot be hacked; this is how we make it hard.

Security in four layers

What protects users today



Edge and browser

HTTPS + HSTS, strict CSP, no framing, WAF, IP rate limits, logs without query strings.



Identity

Short-lived JWT checked twice, role rules on every endpoint, refresh token in an HttpOnly cookie.



Data

BCrypt passwords, strong password policy, schema per service, uploads checked by content.



Money and supply chain

Razorpay signatures, credited once; secret scanning, dependency and image scans.

What the 30 October review fixed

Six findings, all fixed and deployed

Finding	Fix
Refresh token readable by page scripts	HttpOnly, Secure, SameSite=Strict cookie scoped to /api/auth
Weak passwords accepted	10+ chars, letter and digit; no common, leet, sequence or personal passwords
Rate limits keyed on a spoofable header	Railway’s X-Real-IP, then the last proxy hop
Photo and icon links unchecked	Only https:// or same-site paths; no javascript: or data:
Codes and tokens in web-server logs	Query strings masked in nginx access logs
Known npm vulnerabilities	Updated: 0 in all three apps

The reviews engine

New on 30 October: more reviews, more trust, more bookings



Paid

PaymentCompleted opens a review prompt

Asked

Receipt, Rate card and Home banner

Reminded

Once, after 24 h, by push, SMS and in-app

Checked

Fraud checks hold doubtful reviews for staff

Public

Shown on the worker’s page; the worker replies

Public pages never show who wrote a review, and exist only for verified workers.

New endpoints

All behind the gateway; public ones are read-only

Endpoint	Who	Purpose
GET /reviews/prompts/mine	Customer, worker	Jobs waiting for my rating
GET /reviews/received	Worker	Reviews I received
POST /reviews/{id}/reply	Worker (reviewee)	Reply publicly, up to 500 chars
GET /public/workers/{id}	Anyone	Verified worker’s public profile
GET /public/workers/{id}/reviews	Anyone	Rating summary and reviews, paged

From commit to production

Every push to main deploys all services on Railway



Test

Build and unit tests; each failure annotated

Check

Lint, types, gitleaks, Trivy, npm audit

Prove

Booking flow: sign-in to payment to review

Deploy

Merge to main; Railway deploys all services

Verify

Smoke test against the live site

Decisions still open

Owned by the founders; none changed without approval



Go live on payments

Switch the simulator off; add Razorpay live keys.



Remove the fixed OTP

Once MSG91 delivery is confirmed.



Rotate secrets

JWT_SECRET and the test staff password.



Align the platform fee

Payment uses 20% of total; estimates show 10%.

Built to be trusted, tested on every change

Architecture detail: docs/ARCHITECTURE.md and JiHajoor_Architecture.pptx

API reference: docs/API_CONTRACTS.md

© 2026 Ji-Hajoor. Verified Help. Anytime. Anywhere. Powered by Condigence LLP.